

Детекција, инцидент и рањивости

Детекција догађаја, поступање у инциденту и управљање рањивостима

Од безбедносног сигнала до инцидента

Систем ставља сигнал у контекст, процењује утицај и тек затим одређује потребан ниво реакције.

ПРЕДМЕТ АНАЛИЗЕ

Ризик који се анализира

Безбедносни догађај није аутоматски инцидент. Систем најпре препознаје сигнал, затим га ставља у контекст и тек онда одређује да ли је потребна реакција. Такав ток спречава и игнорисање проблема и непотребно алармирање због сваког одступања.

ЗНАЧАЈ

Значај за безбедност система

Управљање инцидентом даје структуру тренутку када је најлакше изгубити контекст. Рањивост постаје решив проблем када је повезана са имовином, приоритетом, власником и доказом да је корекција проверена.

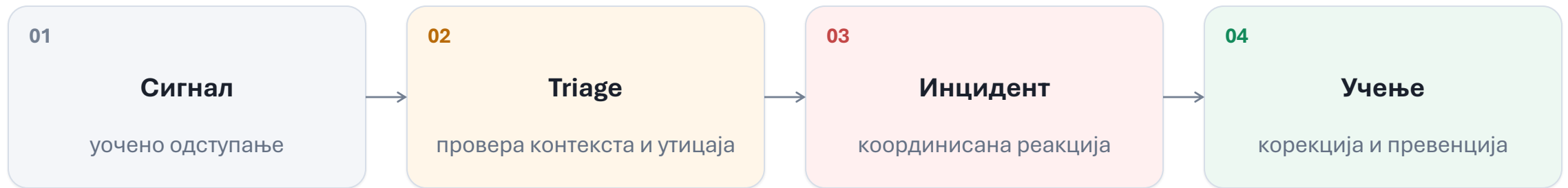
КРИТЕРИЈУМ ПРОВЕРЕ

Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

ОСНОВНИ ПОЈМОВИ

Сигнал, triage, инцидент и учење представљају различите фазе поступања у безбедносном догађају.



ЗАКЉУЧАК

Значајни сигнали пролазе процену контекста и утицаја пре отварања инцидента. Исход анализе остаје доступан за наредне одлуке.

Сигнал

уочено одступање

01

Сигнал настаје када догађаји пређу праг унутар одређеног временског прозора.

Питање: који улаз покреће ову одлуку?

02

Појединачан неуспео покушај није сигнал, а успешне пријаве се не броје.

Питање: која граница мора бити видљива?

03

Сигнал носи контекст: назив правила, субјекта, изворну адресу и број покушаја.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који праг и који временски прозор раздвајају уобичајену грешку од сигнала у вашем систему?

Triage

провера контекста и утицаја

01

Triage додаје сигналу контекст: коју имовину погађа и колики је могући утицај.

Питање: који улаз покреће ову одлуку?

02

Озбиљност се одређује правилом, а не утиском особе која је на дужности.

Питање: која граница мора бити видљива?

03

Одлука се образлаже, укључујући и разлог због ког је упозорење затворено.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који податак о имовини мења озбиљност истог сигнала?

Инцидент

координисана реакција

01

Инцидент настаје из сигнала који је прошао triage и има власника реакције.

Питање: који улаз покреће ову одлуку?

02

Поновљени сигнал се придружује постојећем инциденту уместо да отвара нови.

Питање: која граница мора бити видљива?

03

Временска линија инцидента чува сигнале, одлуке и предузете радње.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Ко у вашој целини преузима инцидент и по ком запису се види шта је урађено?

Учење

корекција и превенција

01

Постинцидентна анализа одваја чињенице од претпоставки насталих под притиском.

Питање: који улаз покреће ову одлуку?

02

Корективна акција има власника и проверљив завршетак.

Питање: која граница мора бити видљива?

03

Сценарио инцидента постаје тест, да се исто знање не изгуби.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који тест бисте додали после инцидента да се исти пропуст не понови?

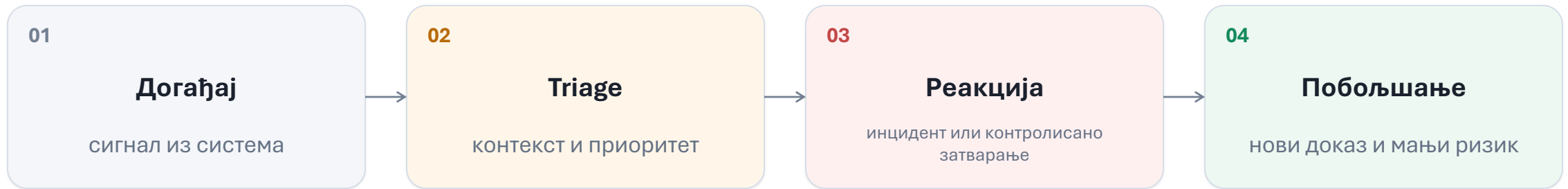
Сигнал, alert и инцидент

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

Стање	Шта представља	Потребна реакција
Сигнал	Сиров догађај или одступање.	Сачувати контекст и проверити правило.
Alert	Сигнал који је прешао дефинисан праг.	Triage и процена приоритета.
Инцидент	Потврђен или вероватан безбедносни утицај.	Координисана реакција и следљив ток.
Налаз рањивости	Потенцијална изложеност коју треба проценити.	Власник, рок и доказ корекције.

Модел одговора на безбедносни догађај

Значајни сигнали пролазе процену контекста и утицаја пре отварања инцидента. Исход анализе остаје доступан за наредне одлуке.



ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

Ток управљања рањивошћу

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

КОНТЕКСТ

Ток управљања рањивошћу

Налаз постаје користан тек када се повеже са стварном имовином и њеном изложеношћу. Исти технички проблем нема исти приоритет на изолованом развојном рачунару и на јавно доступној услузи која обрађује осетљиве податке.

01

Потврдити да се налаз односи на стварну компоненту и активну верзију.

02

Процени утицај у контексту доступности, података и граница поверења.

03

Одредити корекцију, компензациону контролу или образложено прихватање ризика.

04

Затворити налаз тек када постоји доказ да је изложеност проверено смањена.

Сигнал тражи контекст

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01

**Праг детекције треба да има
смисао и разлог, не само
произвољну бројку.**

Јасно правило

02

**Затварање упозорења чува
образложење, јер је то знање за
следећи сличан случај.**

Проверљива примена

03

**Рањивост се сматра решеном
након провере да је ризик
смањен на прихватљив ниво.**

Видљив доказ

Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

РАЗВОЈНИ КОНТЕКСТ

Примена принципа у коду

Тим бира мали број сигнала који су разумљиви оператеру. За сваки описује нормално понашање, разлог активирања, одговорну особу и безбедан начин провере. Тако се детекција дизајнира као производна могућност, а не као споредни лог.

01

Дефинисана одлука и њена граница.

02

Серверска имплементација провере.

03

Позитиван и негативан доказ.

Случај: више неуспелих пријава

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

СЦЕНАРИО

Пример: више неуспелих пријава

Низ неуспелих пријава може значити погрешно запамћену лозинку, проблем интеграције или покушај злоупотребе. Сам број неуспеха зато није довољан за закључак. Triage додаје контекст: да ли су покушаји дошли са истог извора, да ли се односе на осетљиве налоге и да ли се образац наставља након упозорења.

01

Детекција треба да опише образац који је вредан пажње, а не да сваку грешку прогласи инцидентом.

02

Triage чува одлуку и образложење, укључујући разлог због ког је упозорење затворено.

03

Затварање рањивости тражи доказ да је изложеност уклоњена или прихваћена уз видљив преостали ризик.

Правило детекције додаје контекст сигналу

Правило броји неуспеле пријаве по субјекту и адреси унутар временског прозора.

```
1 public IReadOnlyList<SecuritySignal> Detect(  
2     IReadOnlyCollection<LoginAttempt> attempts, DateTimeOffset now)  
3 {  
4     return attempts  
5         .Where(attempt => !attempt.Succeeded && IsInsideWindow(attempt, now))  
6         .GroupBy(attempt => (attempt.SubjectId, attempt.SourceIp))  
7         .Where(group => group.Count() >= _threshold)  
8         .Select(group => new SecuritySignal(  
9             Name, group.Key.SubjectId, group.Key.SourceIp, group.Count()))  
10        .ToArray();  
11 }
```

ТУМАЧЕЊЕ

Праг и временски прозор спречавају да свака неуспела пријава постане сигнал.

БЕЗБЕДНОСНА ГРАНИЦА

Сигнал носи субјекта, адресу и број покушаја, па се може проверити и објаснити.

Испод прага нема сигнала

Тест потврђује да два неуспела покушаја не производе сигнал када је праг три.

```
1 [Test]
2 public void Detect_WhenFailuresAreBelowThreshold_RaisesNothing()
3 {
4     var signals = _rule.Detect(
5         Attempts.Failures("ana", "203.0.113.10", 2, Now), Now);
6
7     Assert.That(signals, Is.Empty);
8 }
```

ДОКАЗ

Негативан сценарио проверава да правило не подиже узбуну пре прага.

ОЧЕКИВАНИ ИСХОД

Тест мења само број покушаја и очекује празну листу сигнала.

Садржај безбедносног записа

Запис садржи контекст потребан за реконструкцију одлуке, без тајни и непотребних личних података.

```
1 {  
2   "signal": "login_failure_spike",  
3   "asset": "admin-portal",  
4   "severity": "high",  
5   "owner": "security-on-call",  
6   "status": "investigating",  
7   "correlationId": "inc-2026-041"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

01

Упозорење без власника и правила за triage.

Нема јасног власника одлуке.

02

Аутоматско затварање без доказа о решавању узрока.

Не постоји негативан сценарио.

03

Скенирање зависности без одлуке како се налаз процењује и прати.

Доказ не показује стварни исход.

Постинцидентна анализа

Анализа повезује узрок, реакцију, пропуст контроле и конкретну корективну меру.

ОБРАЗЛОЖЕЊЕ

Учење након догађаја

Добар пост-инцидент преглед није потрага за особом која је погрешила. Његов циљ је да пронађе где су недостајали сигнал, заштитна провера, јасна одговорност или припрема за опоравак. Резултат треба да мења систем или процес на начин који се може проверити.

01

Хронологија одваја чињенице од претпоставки насталих под притиском.

02

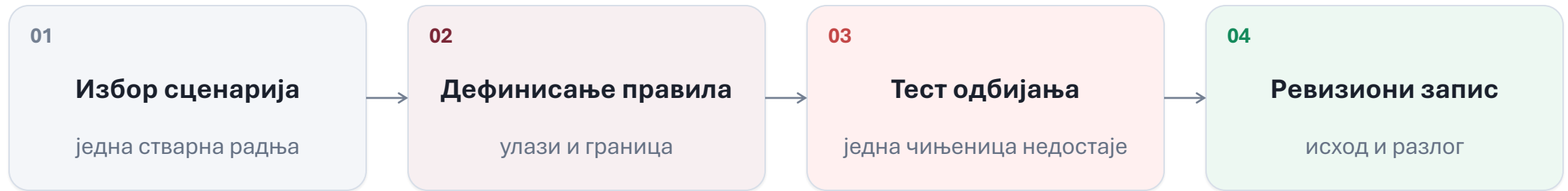
Акције након инцидента имају власника и проверљив завршетак.

03

Нови сценарио се додаје у тестове или оперативне вежбе, како се исто знање не би изгубило.

Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.

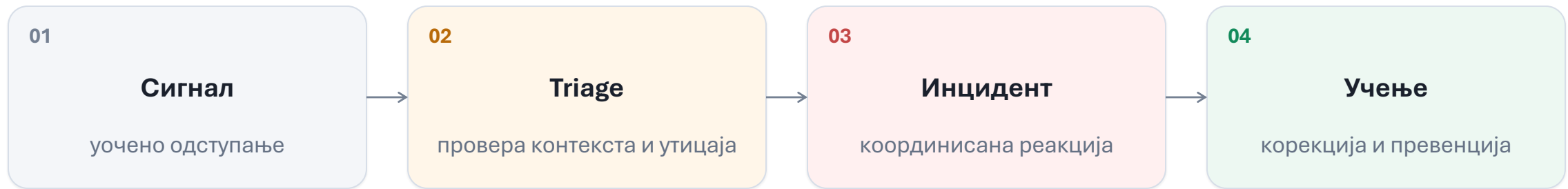


ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Детекција, инцидент и рањивости“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.



ПИТАЊЕ ЗА ПРОВЕРУ

Који догађај би у вашем систему био користан сигнал, али не и довољан доказ инцидента? Који контекст недостаје?

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.